

# Chapter 7: Application Security

## CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

## Learning Objectives

- Understand **application-layer security principles**
- Explain **web browser security settings and risks**
- Identify **add-ons, cookies, and active content threats**
- Apply **secure configuration** and user awareness controls
- Understand **email and document-level protection techniques**

## Overview

Applications and browsers are among the most frequent targets of cyberattacks. Vulnerabilities in software, plugins, and human behavior expose organizations to risk.

 **Goal:** Secure the user environment and application stack from exploitation.

## Web Browser Security

Modern browsers (Chrome, Edge, Firefox, Safari) include multiple security features:

- HTTPS enforcement and certificate validation
- Private/incognito modes
- Pop-up blocking
- Sandboxing of tabs and processes
- Automatic updates

However, **misconfigurations or untrusted extensions** can weaken these protections.

## General Browser Security Recommendations

1. **Keep browsers updated** — patch vulnerabilities quickly.
2. **Disable unnecessary plug-ins or extensions.**
3. **Use secure defaults** — enable HTTPS-Only and Safe Browsing modes.
4. **Clear cache, cookies, and saved passwords** regularly.
5. **Block or limit active content** (JavaScript, Java applets, Flash).
6. **Use strong authentication** for synced browser accounts.

 *Browser hardening significantly reduces attack surface.*

## Web Browser Policies

Security policies should be enforced via system configuration or Group Policy.

### Examples:

- Restrict access to known-safe sites via proxy or whitelist.
- Disable file downloads from unknown sources.
- Enforce minimum TLS version (e.g., TLS 1.2+).
- Disable saving of passwords or autofill for corporate credentials.

Combine administrative policies with user training for best results.

## Active Content Controls

Active web elements (scripts, controls, multimedia) can be exploited to deliver malware.

| Active Content Type | Risk                     | Control                                    |
|---------------------|--------------------------|--------------------------------------------|
| JavaScript          | XSS, drive-by downloads  | Disable or restrict per site               |
| ActiveX             | Arbitrary code execution | Disable or use digitally signed components |
| Flash / Silverlight | Exploited media plugins  | Deprecated — uninstall completely          |
| Java Applets        | Sandboxing bypass        | Block or remove plugin                     |

 **Disable outdated plugins entirely.**

## Cookies and Local Storage

**Cookies:** small text files used to store session and preference data.

**Risks:** session hijacking, tracking, privacy violations.

### Countermeasures:

- Use **Secure** and **HttpOnly** cookie attributes.
- Clear cookies after logout or session end.
- Disable **third-party cookies**.
- Prefer **SameSite** cookie settings ( **Lax** or **Strict** ).

 Review browser privacy settings periodically.



## Locally Shared Objects (LSO)

Also known as **Flash cookies** — store data outside regular cookie storage.

- Persist even after clearing standard browser cookies
- Used for tracking or re-identifying users

**Recommendation:** disable Flash completely or use privacy extensions to remove LSOs.

## Browser Add-ons & Extensions

Browser add-ons extend functionality but can introduce risk.

### **Examples:**

Password managers, VPN plugins, screen capture tools, ad blockers.

### **Best Practices:**

- Install extensions only from trusted sources.
- Regularly review permissions.
- Remove unused or suspicious add-ons.
- Keep all extensions up to date.

## **Advanced Browser Security Settings**

Modern browsers allow granular tuning for:

- **TLS/SSL settings** — enforce secure versions
- **Certificate revocation checks (CRL/OCSP)**
- **Sandboxing policies**
- **Local storage limits and cache control**

Security teams should document standard browser configurations as part of baseline hardening.

# Email and Document Security

Applications like Outlook, Word, or PDF readers can execute malicious content.

## Risks:

- Malicious macros
- Embedded scripts
- Phishing attachments

## Countermeasures:

- Disable macros by default
- Enable Protected View (Office)
- Use antivirus scanning on email attachments
- Digitally sign and encrypt sensitive emails (S/MIME, PGP)

## Digital Signatures & Certificates

- Ensure authenticity and integrity of digital content.
  - Commonly used in:
    - Signed emails
    - Software updates
    - PDF or document verification
  - Use trusted Certificate Authorities (CAs).
-  *Sign your scripts, macros, and executables before distribution.*

## User Account Control (UAC)

**Purpose:** prevent unauthorized changes and escalation of privileges.

- Prompts before running administrative tasks.
- Prevents silent installation of malicious software.
- Should be kept **enabled** on all systems.

UAC is an essential local safeguard against privilege escalation.

## Securing Enterprise Applications

1. Apply vendor security updates promptly.
2. Restrict application permissions (principle of least privilege).
3. Use **application whitelisting** for approved software only.
4. Monitor application logs for anomalies.
5. Perform regular vulnerability scans on business-critical apps.

## Web Application Security Layers

Security at the browser level must integrate with **server-side controls**:

- Use **Web Application Firewalls (WAF)**
- Implement **input validation and sanitization**
- Enforce **TLS/HTTPS** for all communications
- Apply **CSP (Content Security Policy)** to mitigate XSS
- Enable **secure cookie attributes**



## Common Browser Exploits

| Exploit                     | Description                                    | Mitigation                      |
|-----------------------------|------------------------------------------------|---------------------------------|
| <b>Phishing</b>             | Fake login or credential theft                 | Awareness training, MFA         |
| <b>Drive-by Download</b>    | Automatic malware install via compromised site | Disable auto-run, patch browser |
| <b>Clickjacking</b>         | Invisible overlays tricking users into clicks  | Frame-busting, X-Frame-Options  |
| <b>Malicious Extensions</b> | Browser add-ons that exfiltrate data           | Restrict extension installs     |

## Application Hardening Summary

- Update applications and browsers regularly
- Disable or restrict scripts and plugins
- Limit stored credentials and clear session data
- Use secure communication protocols (HTTPS, S/MIME)
- Apply layered defenses: browser settings + network filtering + awareness

## Key Takeaways

- Application security begins with **secure configuration** and **user awareness**
- Browsers are critical attack vectors — maintain least functionality
- Digital signatures, encryption, and policy enforcement ensure trust
- Regular audits and updates are essential for resilience

## End of Chapter 7

**Next:** [Chapter 8 — Secure Software Development Lifecycle \(SDLC\)](#)